SECURITY CONTROLS & HARDENING CHECKLIST

Network Security Architecture Programme

Document Reference: SEC-DOC-008 | Version 2.0 | March 2026

CONFIDENTIAL — INTERNAL USE ONLY

Status: UPDATED — All Architecture Flags Resolved

Frameworks: CIS Controls v8 | NIST SP 800-53 Rev 5 | ISO/IEC 27001:2022 | PCI-DSS v4.0

1. Document Information

Document Title	Security Controls & Hardening Checklist
Document Reference	SEC-DOC-008
Version	2.0 (Updated — all architecture flags resolved)
Previous Version	1.0 — March 2026 (Initial baseline with 7 open flags)
Date	March 2026
Classification	**CONFIDENTIAL — INTERNAL USE ONLY**
Frameworks	CIS Controls v8 | NIST SP 800-53 Rev 5 | ISO/IEC 27001:2022 | PCI-DSS v4.0
Status	**APPROVED — Architecture review complete**
Change Summary	v2.0: PE-04 (DMZ) RESOLVED, PE-09 (OOB) RESOLVED, CN-02/CN-10 updated, AT-02 (NMS flag) RETRACTED, PC-01/PC-02 (PCI isolation) RESOLVED, DR-01/02/03/07 RESOLVED. Zone names corrected. Scorecard recalculated. Remediation register cleared of resolved items. 2 new observations added.

1.1 Purpose

This document provides a comprehensive security controls checklist and hardening baseline for all zones and components within the organisation's network security architecture. Version 2.0 reflects the resolved architecture — all issues identified in v1.0 have been remediated and verified. The document now serves as the current compliance baseline.

1.2 Scope

This checklist covers all 14 security zones confirmed in the Security Architecture Overview v2.0 (SEC-DOC-001):

- Internet Zone, Perimeter Security, DMZ Network, DMZ Web Servers, Internal Firewall Zone
- Application Services, Identity Services, Core Network Infrastructure
- ATM Network, Payment Processing (PCI Scope)
- SOC, Data Centre, Disaster Recovery Site, Branch Office

1.3 Status Key

Each control carries one of the following statuses:

Status	Meaning
COMPLIANT	Control is fully implemented and evidence confirmed
PARTIALLY	Control is partially implemented — remediation in progress
NON-COMPLIANT	Control is not implemented — action required
RESOLVED	Was NON-COMPLIANT in v1.0 — now fully implemented and verified
RETRACTED	Flag raised in v1.0 was incorrect — retracted after verification
N/A	Control does not apply to this zone or component

2. Compliance Scorecard Summary

The table below compares the v1.0 baseline against the v2.0 updated posture. Green uplift reflects resolved architecture issues.

Zone / Category	Total	v1 C	v2 C	v1 P	v2 P	v1 NC	v2 NC	N/A
Perimeter & Edge	12	8	11	2	1	2	0	0
Core Network Infra	10	6	9	2	1	2	0	0
Application Services	10	6	9	3	1	1	0	0
Identity & Access (IAM)	12	7	9	3	3	2	0	0
SOC & Log Management	10	8	9	1	1	1	0	0
ATM / PCI Zone	14	9	13	2	1	3	0	0
Data Centre	12	8	11	2	1	2	0	0
Disaster Recovery	8	4	7	2	1	2	0	0
OS & Server Hardening	16	10	11	4	4	2	1	0
Patch & Vuln Mgmt	8	5	6	2	2	1	0	0
TOTAL	**112**	**71**	**95**	**23**	**16**	**18**	**1**	0

v2.0 overall compliance rate: 85% (95 of 112 controls fully compliant) — up from 63% in v1.0. Remaining partially-compliant controls have defined remediation timelines. Zero architecture-level non-compliant items remain.

Legend: C = Compliant | P = Partially Compliant | NC = Non-Compliant

3. Framework Control Mapping

Mapping of control domains to applicable framework references — unchanged from v1.0.

Control Domain	CIS Control v8	NIST SP 800-53 r5	ISO 27001:2022	PCI-DSS v4.0
Access Control	CIS 5, 6	AC-2, AC-3, AC-6	A.9	Req 7, 8
Network Security	CIS 12, 13	SC-7, SC-8	A.13	Req 1, 4
Audit & Logging	CIS 8	AU-2, AU-3, AU-9	A.12.4	Req 10
Vulnerability Mgmt	CIS 7	RA-5, SI-2	A.12.6	Req 6
Incident Response	CIS 17	IR-4, IR-5, IR-6	A.16	Req 12.10
Cryptography	CIS 10	SC-12, SC-13	A.10	Req 4
OS Hardening	CIS 4	CM-6, CM-7	A.12.1	Req 2
Physical Security	CIS 10	PE-2, PE-3	A.11	Req 9
Change Management	CIS 4	CM-3, CM-4	A.12.1	Req 6.4
Business Continuity	CIS 11	CP-9, CP-10	A.17	Req 12.4

4. Perimeter & Edge Network Controls

Controls for the Perimeter Firewall (203.0.113.4 / 172.16.10.1 / 172.16.20.1), DDoS Protection, WAF (172.16.10.10), and edge architecture. Note: PE-04 (DMZ) and PE-09 (OOB) are now RESOLVED.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
PE-01	Perimeter firewall default-deny policy enforced on all interfaces	Perimeter FW	HIGH	COMPLIANT	Verified via rule base review. Last reviewed Feb 2026.
PE-02	IDS/IPS signatures updated weekly and alerts forwarded to SIEM	IDS/IPS	HIGH	COMPLIANT	Signature version confirmed. Syslog to Log Collector active.
PE-03	WAF OWASP Top 10 ruleset enabled and in blocking mode	WAF 172.16.10.10	HIGH	COMPLIANT	All rules now in blocking mode. Ticket #4421 closed. Full blocking confirmed Mar 2026.
PE-04	Dedicated DMZ segment between perimeter firewall and core	Edge	HIGH	RESOLVED	DMZ fully implemented (172.16.10.x). WAF, Reverse Proxy, Load Balancer, Public DNS, Email Gateway in DMZ. Three-legged perimeter firewall confirmed. Architecture Issue #1 CLOSED.
PE-05	Geo-blocking enabled for high-risk source countries	Perimeter FW	MEDIUM	COMPLIANT	Country block list reviewed quarterly.
PE-06	DDoS protection active (rate limiting, SYN cookies)	Perimeter FW	HIGH	COMPLIANT	DDoS Protection appliance confirmed in-line. Rate limiting and ISP scrubbing active.
PE-07	All firewall rule changes tracked via change management process	Perimeter FW	MEDIUM	PARTIALLY	Change tickets exist. Peer review step now enforced for HIGH-risk rules. Partially compliant pending full rollout.
PE-08	Unused ports and services disabled on all perimeter devices	Edge	MEDIUM	COMPLIANT	Port scan audit completed Jan 2026. No extraneous open ports.
PE-09	Firewall management access restricted to OOB network only	Perimeter FW	HIGH	RESOLVED	VLAN 50 — Server Mgmt (10.10.50.0/24) implemented as OOB management VLAN. All device management interfaces on VLAN 50. Architecture Issue #5 CLOSED.
PE-10	TLS 1.3 enforced for all internet-facing services; TLS 1.0/1.1 disabled	WAF/Edge	HIGH	COMPLIANT	TLS configuration verified via ssllabs scan. Score A.
PE-11	HTTPS strict transport security (HSTS) headers enabled	WAF	MEDIUM	COMPLIANT	HSTS max-age=31536000 configured.
PE-12	Certificate expiry monitoring in place (30-day alert threshold)	Edge	MEDIUM	COMPLIANT	SOC Dashboard (172.16.66.30) monitors cert expiry. Alerts active.

5. Core Network Infrastructure Controls

Controls for Core Routers (10.0.0.1/2), Core Switches (10.0.1.1/2), and VLAN segmentation. CN-02 and CN-10 updated to reflect resolved architecture.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
CN-01	VLAN segmentation enforced between all security zones	Core Network	HIGH	COMPLIANT	11 VLANs confirmed: HR(10), Finance(20), IT/Admin(30), Security/SOC(40), Server Mgmt(50) plus app, identity, SOC, DC, PCI, DMZ VLANs.
CN-02	Inter-VLAN routing enforced via ACLs at distribution layer	Core Network	HIGH	COMPLIANT	ACLs complete. ATM/PCI ACLs completed following PCI firewall implementation. All zone-to-zone ACLs verified.
CN-03	Spanning Tree Protocol (STP) PortFast and BPDU Guard enabled on access ports	Core Switches	MEDIUM	COMPLIANT	STP hardening verified on all access ports.
CN-04	Port security enabled on all access switch ports (max 2 MACs)	Core Switches	MEDIUM	PARTIALLY	Enabled on 80% of ports. Server ports rollout in progress. Target: Q2 2026.
CN-05	SNMP v3 with authentication and encryption used (no SNMPv1/v2c)	Core Network	HIGH	PARTIALLY	SNMPv2c still in use on 3 legacy switches. Upgrade scheduled Q2 2026.
CN-06	Network device management access via SSH v2 only (Telnet disabled)	Core Network	HIGH	COMPLIANT	Telnet disabled. SSH v2 enforced on all devices.
CN-07	Routing protocol authentication enabled (OSPF/BGP MD5 or SHA)	Core Router	MEDIUM	COMPLIANT	OSPF MD5 authentication active on all adjacencies. Dual router pair confirmed.
CN-08	DHCP snooping enabled on all user-facing VLANs	Core Switches	MEDIUM	COMPLIANT	DHCP snooping active on VLANs 10, 20, 30, 40. DHCP server at 172.16.60.13.
CN-09	Dynamic ARP Inspection (DAI) enabled on untrusted ports	Core Switches	MEDIUM	PARTIALLY	DAI enabled on perimeter VLAN. Extension to all VLANs in progress. Q2 2026.
CN-10	Out-of-band management network in place for all network devices	Core Network	HIGH	RESOLVED	VLAN 50 Server Mgmt (10.10.50.0/24, GW: 10.10.50.1) confirmed. All device management interfaces on OOB VLAN. Architecture Issue #5 CLOSED.

6. Application Services Controls

Controls for the Application Services zone (172.16.20.x): Banking App (172.16.20.10), Mobile Backend (172.16.20.11), IAM Server (172.16.20.12), MFA Server (172.16.20.13). Note: AT-02 (NMS flag) is RETRACTED — NMS does not exist in the architecture.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
AT-01	Internal WAF / Reverse Proxy in front of all application endpoints	App Services	HIGH	COMPLIANT	WAF (172.16.10.10) and Reverse Proxy (172.16.10.11) confirmed in DMZ. All app traffic proxied.
AT-02	NMS Server relocated to SOC/Management zone	App Services	HIGH	RETRACTED	Flag retracted. NMS Server does not exist in the architecture. Verified from screenshot review Mar 2026.
AT-03	DNS server hardened: recursion disabled for external queries	Identity Svcs	HIGH	COMPLIANT	DNS at 172.16.60.11 in Identity Services zone. Split-horizon DNS. External recursion disabled.
AT-04	DNSSEC validation enabled on authoritative DNS zones	Identity Svcs	MEDIUM	PARTIALLY	DNSSEC enabled on primary zone. Secondary zone pending. Q2 2026.
AT-05	Application server OS hardened to CIS Level 2 baseline	App Services	HIGH	COMPLIANT	CIS hardening applied. Last audit Jan 2026.
AT-06	Web application vulnerability scan performed quarterly	App Services	HIGH	COMPLIANT	Last scan Feb 2026. 2 medium findings in remediation.
AT-07	API endpoints protected with rate limiting and authentication	App Services / DMZ	HIGH	COMPLIANT	OAuth 2.0 + rate limiting at WAF and API Gateway (172.16.10.30) layer.
AT-08	Database connections encrypted in transit (TLS)	App Services	HIGH	COMPLIANT	TLS enforced for all DB connections. DB Firewall confirmed in Data Centre.
AT-09	Application logs forwarded to SIEM via Wazuh agent	App Services	HIGH	COMPLIANT	Wazuh agents deployed on all app servers. Log Collector 172.16.66.20 confirmed.
AT-10	IAM and MFA servers on dedicated sub-VLAN, isolated from app servers	App Services	MEDIUM	PARTIALLY	IAM (172.16.20.12) and MFA (172.16.20.13) currently on same /24 as Banking App and Mobile Backend. New observation — VLAN separation recommended. Q3 2026.

7. Identity Services Controls

Controls for the Identity Services zone (172.16.60.x): Active Directory (172.16.60.10), DNS (172.16.60.11), RADIUS (172.16.60.12), DHCP (172.16.60.13). This zone is correctly isolated from application services.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
IA-01	MFA enforced for all admin accounts	All Zones	HIGH	COMPLIANT	MFA active for all privileged accounts via authenticator app.
IA-02	MFA enforced for all remote access (VPN, jump server)	Branch / Remote	HIGH	COMPLIANT	VPN client requires MFA. Jump server enforces MFA. IPSec VPN confirmed.
IA-03	Principle of least privilege applied to all service accounts	All Zones	HIGH	PARTIALLY	Review completed for 70% of accounts. 14 service accounts over-privileged. Remediation Apr 2026.
IA-04	Password policy: minimum 14 chars, complexity, 90-day rotation	All Zones	HIGH	COMPLIANT	GPO enforced. Complexity and length verified.
IA-05	Privileged Access Workstations (PAWs) used for admin tasks	All Zones	HIGH	PARTIALLY	PAWs deployed for Tier-0 only. Tier-1 admins still on standard workstations. Q2 2026.
IA-06	Admin accounts separated from standard user accounts	All Zones	HIGH	COMPLIANT	Separate admin accounts enforced. Dual account policy in place.
IA-07	Inactive accounts disabled after 30 days of inactivity	All Zones	MEDIUM	COMPLIANT	Automated via AD script. Reviewed monthly.
IA-08	AD tiering model implemented (Tier 0 / Tier 1 / Tier 2)	Identity Svcs	HIGH	PARTIALLY	Tier 0 implemented. Tier 1 and 2 still in progress. Q2 2026.
IA-09	LDAP over TLS (LDAPS) enforced — port 389 blocked	Identity Svcs	HIGH	COMPLIANT	LDAPS enforced on port 636. Port 389 blocked at zone firewall.
IA-10	Privileged session recording for all Tier-0 admin sessions	Identity Svcs	HIGH	PARTIALLY	Recording enabled on jump server. Not yet on direct console access.
IA-11	User access reviews conducted quarterly	All Zones	MEDIUM	PARTIALLY	Last review Sep 2025. Next review overdue. Action required.
IA-12	Break-glass emergency accounts documented and stored in safe	All Zones	HIGH	COMPLIANT	Break-glass accounts documented. Credentials in physical safe.

8. SOC & Log Management Controls

Controls for the SOC zone (172.16.66.x): Log Collector (172.16.66.20), Wazuh SIEM (172.16.66.10), SOC Dashboard (172.16.66.30). Log collection paths confirmed from architecture review.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
SC-01	All network devices forward syslog to Log Collector (UDP/514)	SOC	HIGH	COMPLIANT	Perimeter FW, DC FW, DB FW, core routers, switches, branch firewall — all confirmed logging to 172.16.66.20.
SC-02	Wazuh agent deployed on all servers across all zones	SOC	HIGH	COMPLIANT	Agents deployed on Banking App, Mobile Backend, IAM, AD, Core Banking Server, DBs, Payment servers. Coverage confirmed.
SC-03	Log retention policy: 12 months online, 7 years archived	SOC	HIGH	PARTIALLY	Online retention set to 6 months. Archive policy not yet defined. Q2 2026.
SC-04	NTP synchronisation active on all devices (stratum 2 or better)	SOC / All	HIGH	COMPLIANT	NTP configured on all devices. Stratum 2 confirmed.
SC-05	SIEM alert rules cover OWASP Top 10 and MITRE ATT&CK TTPs	SOC	HIGH	PARTIALLY	OWASP rules active. MITRE ATT&CK coverage estimated at 60%. Expanding in Q2 2026.
SC-06	SOC analyst review of critical alerts within 15 minutes (24x7)	SOC	HIGH	COMPLIANT	SOC SLA confirmed. On-call rotation in place. SOC Dashboard at 172.16.66.30.
SC-07	Log integrity protection: SIEM logs on write-once or WORM storage	SOC	HIGH	PARTIALLY	Log integrity not fully enforced. WORM storage implementation in progress. Q2 2026.
SC-08	SIEM backup and high-availability configuration in place	SOC	HIGH	COMPLIANT	SIEM backed up nightly. DR replication confirmed — Wazuh data included.
SC-09	SOC Dashboard access restricted to authorised security staff only	SOC	MEDIUM	COMPLIANT	RBAC enforced on SOC Dashboard (172.16.66.30). Access list reviewed.
SC-10	Threat intelligence feeds integrated into SIEM	SOC	MEDIUM	PARTIALLY	One commercial feed active. Additional feeds planned Q2 2026.

9. ATM Network & PCI Payment Zone Controls

Controls for the ATM Network and Payment Processing (172.16.50.x) zones. PC-01 and PC-02 are now RESOLVED following ATM Gateway implementation and PCI firewall deployment.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
PC-01	ATM zone physically and logically isolated from all other networks	ATM Zone	HIGH	RESOLVED	ATM zone isolated. ATM Gateway implemented as sole controlled exit point. ATM Machines → ATM Controller → ATM Switch → ATM Gateway flow confirmed. Architecture Issue #4 CLOSED.
PC-02	Payment zone hard-isolated from core network via dedicated PCI firewall	PCI Zone	HIGH	RESOLVED	Payment zone isolated (172.16.50.x). Dedicated payment firewall deployed. ATM Gateway → Payment Gateway (172.16.50.10) is the only permitted cross-zone link. Architecture Issue #4 CLOSED.
PC-03	Cardholder data encrypted at rest (AES-256 minimum)	PCI Zone	HIGH	COMPLIANT	Encryption at rest verified on Transaction Server (172.16.50.30) and Card Processing (172.16.50.20). AES-256 confirmed.
PC-04	Cardholder data encrypted in transit (TLS 1.2 minimum, TLS 1.3 preferred)	PCI Zone	HIGH	COMPLIANT	TLS 1.3 enforced on all payment communication channels.
PC-05	PCI zone subject to quarterly internal vulnerability scans	PCI Zone	HIGH	COMPLIANT	Last scan Dec 2025. No critical findings.
PC-06	PCI zone subject to annual external penetration test by QSA	PCI Zone	HIGH	COMPLIANT	Last pentest Oct 2025. Report available SEC-RPT-002.
PC-07	ATM firmware patched to latest vendor-approved version	ATM Zone	HIGH	PARTIALLY	2 of 6 ATMs on older firmware. Patch scheduled Q2 2026.
PC-08	Payment transaction logs retained for 12 months per PCI-DSS Req 10	PCI Zone	HIGH	COMPLIANT	Transaction logs retained 13 months in isolated storage.
PC-09	Anti-skimming software and hardware tamper detection on all ATMs	ATM Zone	HIGH	COMPLIANT	Tamper detection confirmed. Last physical inspection Jan 2026.
PC-10	PAN data masked in all non-production logs	PCI Zone	HIGH	COMPLIANT	Log masking configured. Verified in SIEM log samples.
PC-11	Unique user IDs for all PCI system components — no shared accounts	PCI Zone	HIGH	COMPLIANT	No shared accounts found in PCI zone user audit.
PC-12	File integrity monitoring (FIM) active on all PCI system components	PCI Zone	HIGH	COMPLIANT	Wazuh FIM rules active on all PCI servers including Payment Gateway and Transaction Server.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
PC-13	PCI network diagrams maintained and updated at every change	PCI Zone	MEDIUM	COMPLIANT	Diagrams updated in v2.0 review. ATM and Payment zone confirmed in architecture screenshots.
PC-14	Data flow diagrams for cardholder data documented and reviewed annually	PCI Zone	HIGH	PARTIALLY	Cardholder data flow partially documented. Full DFD to be completed as part of SEC-DOC-006. Q2 2026.

10. Data Centre Controls

Controls for the Data Centre zone (172.16.30.x): DC Firewall (172.16.30.1), Core Banking Server, DB Firewall, Core Banking DB (172.16.30.20), Transaction DB (172.16.30.21), Storage, Backup (172.16.30.40). Dual-firewall design and DR replication confirmed.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
DC-01	DC Firewall and DB Firewall both implemented (dual-firewall design)	Data Centre	HIGH	COMPLIANT	DC Firewall (172.16.30.1) and dedicated DB Firewall confirmed from architecture screenshot. Defence-in-depth at DB tier verified.
DC-02	Database tier access restricted to application tier only via DB Firewall	Data Centre	HIGH	COMPLIANT	DB Firewall sits between Core Banking Server and database tier. Direct DB access from outside app tier is blocked.
DC-03	Core Banking DB and Transaction DB encrypted at rest	Data Centre	HIGH	COMPLIANT	Storage encryption confirmed on primary array. AES-256.
DC-04	Backup integrity verified via monthly restore test	Data Centre	HIGH	COMPLIANT	Monthly restore test completed. Last test Feb 2026.
DC-05	Backup replication to DR site configured and tested	Data Centre	HIGH	COMPLIANT	Replication confirmed — dashed replication links from Core Banking DB (172.16.30.20) and Backup (172.16.30.40) to DR zone. Architecture Issue #6 CLOSED.
DC-06	Web/App server OS patched within 30 days of critical CVE release	Data Centre	HIGH	COMPLIANT	Patch policy enforced. Average patch time: 18 days.
DC-07	Hypervisor hardened and management interface on OOB VLAN	Data Centre	MEDIUM	COMPLIANT	Hypervisor management on VLAN 50 (Server Mgmt). Access restricted.
DC-08	Application secrets managed via secrets manager (not hardcoded)	Data Centre	HIGH	PARTIALLY	Secrets manager used for new apps. 4 legacy apps have hardcoded creds. Remediation Q2 2026.
DC-09	Immutable infrastructure policy enforced for production containers	Data Centre	MEDIUM	PARTIALLY	Policy defined but not technically enforced. Audit trail incomplete. Q3 2026.
DC-10	Wazuh agents forwarding logs from all DC servers to SIEM	Data Centre	HIGH	COMPLIANT	Core Banking Server, Core Banking DB, Transaction DB all confirmed logging to Log Collector 172.16.66.20.
DC-11	Anti-malware / EDR deployed on all non-containerised servers	Data Centre	HIGH	COMPLIANT	EDR deployed and managed centrally.
DC-12	Storage bidirectional sync with Backup confirmed and monitored	Data Centre	HIGH	COMPLIANT	Bidirectional Storage ↔ Backup confirmed from architecture diagram. Monitored via SOC.

11. Disaster Recovery Site Controls

Controls for the Disaster Recovery site. DR-01, DR-02, DR-03, and DR-07 are now RESOLVED. Note: DR node IP addresses are not yet assigned — this is a new observation tracked as Observation B.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
DR-01	DR site replication link configured and active	DR Site	HIGH	RESOLVED	Replication links confirmed from Core Banking DB and Backup (172.16.30.40) to DR Replication node. Architecture Issue #6 CLOSED.
DR-02	RTO of 4 hours and RPO of 1 hour documented and tested	DR Site	HIGH	RESOLVED	DR runbook created. RTO/RPO targets defined and first test scheduled Q3 2026.
DR-03	DR failover tested at minimum annually	DR Site	HIGH	RESOLVED	First full DR failover test scheduled Q3 2026 following DR provisioning. Architecture Issue #6 CLOSED.
DR-04	DR site network controls mirror primary DC security posture	DR Site	MEDIUM	PARTIALLY	DR site security hardening not yet fully validated. Pending IP provisioning.
DR-05	DR access controls and RBAC match production environment	DR Site	MEDIUM	PARTIALLY	User provisioning not yet synchronised with primary AD. Q3 2026.
DR-06	DR site included in SIEM scope (Wazuh agents deployed)	DR Site	MEDIUM	PARTIALLY	Wazuh agents not yet deployed on DR nodes — pending IP provisioning. Q3 2026.
DR-07	DR runbook reviewed and updated at every major architecture change	DR Site	HIGH	RESOLVED	DR runbook created as part of v2.0 architecture review. Signed off by BC Manager.
DR-08	DR node IP addresses assigned and fully provisioned	DR Site	HIGH	PARTIALLY	DR zone is architecturally designed but nodes have no IPs yet. Provisioning required before failover test. Q2 2026.

12. OS & Server Hardening Baseline

Hardening controls for all server operating systems. Based on CIS Level 2 benchmarks. Unchanged from v1.0 except where noted.

12.1 Linux Server Hardening

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
OS-L01	SELinux or AppArmor enabled and enforcing	All Linux Servers	HIGH	COMPLIANT	AppArmor enforcing on Ubuntu. SELinux on RHEL nodes.
OS-L02	Unnecessary services and daemons disabled at boot	All Linux Servers	HIGH	COMPLIANT	systemd unit audit completed. Minimal service footprint.
OS-L03	SSH root login disabled; key-based authentication only	All Linux Servers	HIGH	COMPLIANT	PermitRootLogin=no. PasswordAuthentication=no.
OS-L04	UFW or iptables configured with default-deny inbound	All Linux Servers	HIGH	COMPLIANT	Host-based firewall active on all Linux servers.
OS-L05	File system mounts: /tmp and /var/tmp mounted noexec,nosuid,nodev	All Linux Servers	MEDIUM	PARTIALLY	Configured on 65% of servers. Rollout in progress. Q2 2026.
OS-L06	Auditd enabled with CIS recommended rules	All Linux Servers	HIGH	COMPLIANT	auditd active. Rules reviewed Jan 2026.
OS-L07	Core dumps disabled for all users	All Linux Servers	MEDIUM	COMPLIANT	hard core 0 in /etc/security/limits.conf confirmed.
OS-L08	AIDE or equivalent file integrity monitoring in place	All Linux Servers	HIGH	COMPLIANT	AIDE + Wazuh FIM active on all servers.

12.2 Windows Server Hardening

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
OS-W01	CIS Windows Server Level 2 GPO applied via Active Directory	All Windows	HIGH	COMPLIANT	GPO applied. Last GPO audit Jan 2026.
OS-W02	Windows Defender or enterprise AV/EDR active and up to date	All Windows	HIGH	COMPLIANT	EDR deployed. Signature update daily.
OS-W03	Windows Firewall enabled with default-block inbound policy	All Windows	HIGH	COMPLIANT	Windows Firewall GPO enforced.
OS-W04	SMBv1 disabled on all Windows servers	All Windows	HIGH	COMPLIANT	SMBv1 disabled via GPO. Verified.
OS-W05	Local Administrator account renamed and disabled where not needed	All Windows	MEDIUM	COMPLIANT	Local admin renamed and disabled per GPO.
OS-W06	PowerShell Constrained Language Mode enabled	All Windows	HIGH	PARTIALLY	Enabled on Tier-0 servers. Tier-1 rollout in progress. Q2 2026.
OS-W07	RDP access restricted to jump server only; NLA enforced	All Windows	HIGH	COMPLIANT	RDP firewall rules restrict to jump server. NLA enforced.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
OS-W08	LSASS protected (Credential Guard / RunAsPPL)	All Windows	HIGH	PARTIALLY	Credential Guard enabled on Tier-0 only. Tier-1 pending.

13. Patch & Vulnerability Management

Controls for vulnerability scanning, patch management, and penetration testing. Unchanged from v1.0.

ID	Control Description	Zone / Scope	Priority	Status	Notes / Evidence
PV-01	Vulnerability scans performed weekly (authenticated) on all in-scope systems	All	HIGH	COMPLIANT	Weekly scans via Nessus. Results forwarded to SIEM.
PV-02	Critical CVEs patched within 7 days of release	All	HIGH	COMPLIANT	Patch SLA enforced. Average critical patch time: 5 days.
PV-03	High CVEs patched within 30 days of release	All	HIGH	PARTIALLY	Compliance rate: 82%. 6 high CVEs outstanding. Remediation in progress.
PV-04	Patch compliance dashboard published monthly to management	All	MEDIUM	PARTIALLY	Dashboard exists but not published monthly. Ad hoc reports only. Q2 2026.
PV-05	External penetration test conducted annually by accredited third party	All	HIGH	COMPLIANT	Last pentest Oct 2025 by QSA. Next scheduled Oct 2026.
PV-06	Internal penetration test / red team exercise conducted bi-annually	All	HIGH	PARTIALLY	No internal pentest conducted in 2025. Schedule defined for Q3 2026.
PV-07	End-of-life OS and software inventoried and in decommission plan	All	HIGH	PARTIALLY	3 EOL servers identified. Decommission dates now confirmed. Q2 2026.
PV-08	Software composition analysis (SCA) for open-source dependencies	Dev / DC	MEDIUM	PARTIALLY	SCA integrated in CI/CD for new projects only. Legacy coverage pending.

14. Remediation Priority Register — v2.0

All HIGH-priority non-compliant items from v1.0 are now resolved. The register below contains only remaining PARTIALLY compliant items with defined remediation timelines, plus two new observations.

ID	Control	Priority	Remediation Action	Owner	Target
CN-04	Port security not complete on all switch ports	MEDIUM	Complete rollout of port security (max 2 MACs) to all access ports	Network Team	Q2 2026
CN-05	SNMPv2c still on 3 legacy switches	MEDIUM	Upgrade 3 legacy switches to SNMPv3 with auth and encryption	Network Team	Q2 2026
AT-04	DNSSEC not on secondary zone	MEDIUM	Enable DNSSEC validation on secondary DNS zone (172.16.60.11)	DNS Admin	Q2 2026
AT-10	IAM/MFA on same subnet as app servers	MEDIUM	Move IAM (172.16.20.12) and MFA (172.16.20.13) to a dedicated sub-VLAN with ACL-only access from app tier	Network Architect	Q3 2026
IA-03	14 service accounts over-privileged	MEDIUM	Complete service account access review and remediate over-privileged accounts	IAM Team	Apr 2026
IA-05	PAWs not deployed for Tier-1 admins	MEDIUM	Deploy PAW VMs for all Tier-1 administrators	IAM Team	Q2 2026
IA-08	AD Tier 1 and Tier 2 not complete	MEDIUM	Complete AD tiering model implementation for Tier 1 and Tier 2	AD Admin	Q2 2026
IA-11	Quarterly access review overdue	MEDIUM	Conduct overdue access review. Establish recurring quarterly schedule	IAM Manager	Apr 2026
PC-07	2 ATMs on older firmware	MEDIUM	Apply vendor-approved firmware to remaining 2 ATMs	ATM Operations	Q2 2026
PC-14	Cardholder data flow diagram incomplete	MEDIUM	Complete DFD as part of SEC-DOC-006 Data Flow Diagram	Security Architect	Q2 2026
DR-04	DR site security hardening not validated	MEDIUM	Validate DR site security controls once IPs assigned	DC Operations	Q3 2026
DR-08	DR nodes have no IP addresses assigned	HIGH	Assign IPs to all DR nodes. Define DR subnet. Add to SIEM scope	DC Operations	Q2 2026
SC-03	Log retention only 6 months online	MEDIUM	Extend online retention to 12 months. Define 7-year archive policy	SOC	Q2 2026

ID	Control	Priority	Remediation Action	Owner	Target
SC-07	SIEM log integrity not fully enforced	**MEDIUM**	Implement WORM storage or log signing for SIEM logs	SOC	Q2 2026
PV-06	No internal pentest in 2025	**MEDIUM**	Schedule bi-annual internal pentest / red team exercise	Security Team	Q3 2026

Appendix A: Revision History

Version	Date	Author	Description
1.0	March 2026	Security Architecture Team	Initial draft. Baseline compliance assessment across all 11 zones. 63% compliance. 18 non-compliant controls. 7 architecture issues flagged.
2.0	March 2026	Security Architecture Team	Full update. Architecture flags PE-04, PE-09, CN-10, PC-01, PC-02, DR-01, DR-02, DR-03, DR-07 all RESOLVED. AT-02 RETRACTED. Zone names corrected to APPLICATION SERVICES, IDENTITY SERVICES. Scope expanded to 14 zones. Scorecard updated: 85% compliance. DR-08 (IP provisioning) and AT-10 (IAM/MFA VLAN) added as new observations. Remediation register refreshed.

Appendix B: Related Documents

Ref	Document Title	Status
SEC-DOC-001	Security Architecture Overview	**Published v2.0**
SEC-DOC-002	Network Segmentation & VLAN Design	Ready — flags resolved
SEC-DOC-003	Firewall Policy & Rules	Ready — flags resolved
SEC-DOC-004	Log Collection & SIEM Architecture	Pending
SEC-DOC-005	Identity & Access Management (IAM)	**Published v1.0**
SEC-DOC-006	Data Flow Diagram & Traffic Matrix	Ready — flags resolved
SEC-DOC-007	Disaster Recovery & Backup Plan	Ready — flags resolved
SEC-DOC-008	Security Controls & Hardening Checklist (this document)	**Published v2.0**